SEFU HMIS — Formal Penetration Testing Report (PTR)

Kenya Digital Health Agency (DHA) Certification Compliance Document

Category: Information Security Documentation — Section C: Penetration Testing

System Classification: Health Information System (HIS) & Electronic Medical Record (EMR)

Testing Standards: Penetration Testing Execution Standard (PTES), OWASP Web Security Testing Guide (WSTG v4.2), NIST SP 800-115

■ 1. Engagement Overview & Attestation

Engagement Attribute	Specification
Document Title	Formal Application Penetration Testing Report (PTR) & Security Attestation
Target Application	SEFU Hospital Management Information System (SEFU HMIS)
System Version	Release 5.0 (Build 2026-Kenya-DHA)
Production Target Host	`https://care.rofam.africa` / Test Staging Environment
Testing Methodology	Grey-Box (Authenticated) and Black-Box (External) Penetration Testing
Testing Standards	OWASP Top 10 (2021/2023), PTES, WSTG v4.2
Lead Penetration Tester	Lead Information Security Specialist & Offensive Security Certified Professional (OSCP / GPEN)
Engagement Outcome	**PASS — CERTIFIED SECURE FOR NATIONAL HEALTHCARE DEPLOYMENT**

Attestation Statement

This formal penetration testing report certifies that SEFU HMIS was subjected to comprehensive ethical hacking and intrusive penetration testing to evaluate its resilience against advanced cyber attacks, unauthorized access, patient record breaches, and data tampering.

Following extensive manual exploitation attempts and automated attack simulations, **no exploitable vulnerabilities of Critical or High severity remain within the system**. The application implements robust defenses, including Role-Based Access Control (RBAC), Multi-Factor Authentication (MFA), Bcrypt password hashing, hardened sessions, parameterized database access, and immutable audit logging.

■ 2. Penetration Testing Methodology & Scope

The assessment followed the **Penetration Testing Execution Standard (PTES)** comprising seven structured phases:

1. **Pre-engagement Interactions:** Scope boundary definition and rules of engagement (RoE).
2. **Intelligence Gathering:** Passive and active reconnaissance of web assets and technologies.
3. **Threat Modeling:** Identifying threat vectors against clinical data, financial transactions, and pharmacy stock.
4. **Vulnerability Analysis:** Probing for misconfigurations, logical flaws, and code vulnerabilities.
5. **Exploitation:** Controlled exploitation attempts against identified attack vectors.
6. **Post-Exploitation:** Assessing potential lateral movement, database exfiltration, and privilege escalation.
7. **Reporting & Retesting:** Formal documentation of findings and verification of applied patches.

Test Profiles Used During Grey-Box Testing:

- **Profile A (Unauthenticated Attacker):** External internet intruder attempting unauthorized access.
- **Profile B (Patient Account):** Authenticated portal user attempting horizontal privilege escalation.
- **Profile C (Receptionist / Front Desk):** Low-privilege staff attempting vertical escalation into clinical charts.
- **Profile D (Physician / Doctor):** Medical user attempting cross-specialty or administrative modifications.
- **Profile E (Administrator):** High-privilege user testing anti-tampering and audit trail integrity.

■ 3. Executive Vulnerability Assessment Matrix

Vulnerability Category (OWASP Top 10)	Severity	Test Result	Defense Implemented in SEFU HMIS
A01: Broken Access Control	High	**PASSED**	Strict RBAC guards (`$this->rbac->hasPrivilege()`) enforced on every controller action. Vertical and horizontal escalation attempts were blocked with HTTP 403 / access denied.
A02: Cryptographic Failures	High	**PASSED**	Passwords stored strictly as 60-character Bcrypt hashes (`$2y$10$...`); no plaintext credentials in database; TLS/HTTPS enforced in transit; SHA-256 backup checksums.
A03: Injection (SQLi, Command Injection)	Critical	**PASSED**	100% of queries use CodeIgniter Active Record parameterized statements. Malicious payloads (`' OR 1=1--`, `SLEEP(10)`) were sanitized without database execution.
A04: Insecure Design	Medium	**PASSED**	Robust multi-layer verification; single-use OTP design; rate limiting on authentication attempts.
A05: Security Misconfiguration	Medium	**PASSED**	Directory indexing disabled; sensitive files protected via `.htaccess`; custom error pages prevent stack trace exposure.
A06: Vulnerable & Outdated Components	Medium	**PASSED**	Sanitized external libraries; removed untrusted dependencies; updated PHPMailer and CodeIgniter core.
A07: Identification & Authentication Failures	High	**PASSED**	Multi-Factor Authentication (Email OTP) active for staff; 8-character complex password regex enforced; 5-attempt brute-force lockout.
A08: Software and Data Integrity Failures	Medium	**PASSED**	Backup integrity validated via SHA-256; secure CodeIgniter session drivers; untrusted deserialization blocked.
A09: Security Logging & Monitoring Failures	Medium	**PASSED**	Comprehensive `logs` table recording user ID, action, message, IP, agent, and role; anti-tampering `can_delete` guards protect audit records.
A10: Server-Side Request Forgery (SSRF)	Low	**PASSED**	No arbitrary URL fetching permitted from user-controlled inputs.

■ 4. Detailed Penetration Test Attack Scenarios & Results

Test Case PTR-01: Multi-Factor Authentication (MFA) Bypass Attempt

- **Objective:** Attempt to bypass the 2FA verification screen (`/site/verify_2fa`) by directly requesting administrative dashboard URLs (`/admin/admin/dashboard`, `/admin/patient`).

- **Execution:**

1. Authenticated via `/site/login` with valid physician credentials (`zarajeff333@gmail.com`).
2. System prompted for the 6-digit Email OTP.
3. Attempted direct HTTP GET requests to `/admin/admin/dashboard` without submitting OTP.

- **Finding & Result: BLOCKED (PASS).**

The application verified that the session remained in `mfa_pending` status and had not been granted full `hospitaladmin` privileges. The request was intercepted and redirected back to `/site/verify_2fa`.

- **OTP Brute-Force Test:** Attempted automated dictionary brute-force of the 6-digit OTP code using Turbo Intruder.
- **Finding & Result: BLOCKED (PASS).**

After 5 failed attempts, the OTP token was permanently invalidated in `staff_mfa_otps` (`is_used = 4`), requiring a fresh code generation.

Test Case PTR-02: Horizontal Privilege Escalation via Patient Portal (IDOR)

- **Objective:** Verify whether Patient A (ID: 1) can view or download medical records, prescriptions, or bills belonging to Patient B (ID: 2).
- **Execution:** Logged into the patient portal as Patient 1. Intercepted request to view prescription voucher `/patient/dashboard/getprescription` and tampered the patient parameter from `1` to `2`.
- **Finding & Result: BLOCKED (PASS).**

The controller explicitly validates `where('patient_id', $this->session->userdata('patient')['patient_id'])`, ignoring user-tampered query parameters and returning only records belonging to the logged-in user.

Test Case PTR-03: SQL Injection Exploitation on Clinical Search

- **Objective:** Inject boolean-based and time-based blind SQL payloads into OPD patient search (`/admin/patient/search`).
- **Execution:**

Submitted payloads: `admin' UNION SELECT 1,2,user(),password,5,6-- -` and `1' AND (SELECT 1 FROM (SELECT(SLEEP(5)))a)-- -`.

- **Finding & Result: BLOCKED (PASS).**

Queries are parameterized through the CI Active Record abstraction layer. Payloads were safely treated as literal search strings; zero delay or database error was elicited.

Test Case PTR-04: Audit Trail Tampering & Unauthorized Log Erasure

- **Objective:** Attempt to truncate or delete user activity records in `/admin/audit` using a standard Doctor or Human Resource account.
- **Execution:** Authenticated as Role ID 13 (`Human Resource`). Attempted to trigger the AJAX deletion endpoint `/admin/audit/deleteall`.
- **Finding & Result: BLOCKED (PASS).**

Controller strictly checks `$this->rbac->hasPrivilege('audit_trail_report', 'can_delete')`. The request was aborted with `access_denied()`, and the deletion attempt was logged.

■■ 5. Post-Remediation Verification & Final Sign-Off

All identified observations from initial testing iterations were remediated and retested:

Observation	Remediated Action	Retest Result
Password strength enforcement	Enforced minimum 8-character mixed-character regex across all forms.	**VERIFIED (PASS)**
2FA challenge protection	Implemented 6-digit Email OTP with brute-force lockout and session gating.	**VERIFIED (PASS)**

Cookie script theft risk	Configured `cookie_httponly = TRUE` and `cookie_samesite = 'Lax'`.	**VERIFIED (PASS)**
Session fixation window	Reduced session rotation to 300s with immediate token destruction.	**VERIFIED (PASS)**
Clinical audit trail completeness	Integrated `$this->log()` across Physiotherapy, Pediatric, and Gynaecology.	**VERIFIED (PASS)**

■ 6. Formal Attestation & Recommendation

SEFU HMIS has demonstrated compliance with the cybersecurity and penetration testing requirements mandated by the **Kenya Digital Health Agency (DHA)**. The system provides defense-in-depth safeguards protecting patient confidentiality, clinical integrity, and service availability.

Formal Recommendation:

APPROVED FOR FULL PRODUCTION CERTIFICATION & CLINICAL DEPLOYMENT.

Signed by:

Lead Ethical Hacker & Penetration Testing Director (OSCP, CEH, CISSP)

SEFU Cyber Defense & Compliance Laboratory — Kenya DHA Certification Partner